

TỔNG QUAN AN TOÀN MẠNG MÁY TÍNH

9/16/2025

ThS. Nguyễn Duy
duyn@uit.edu.vn

Nội Dung

2

9/16/2025

- Bảo mật thông tin là gì
- Những thách thức trong bảo mật thông tin
- Những dạng tấn công cơ bản trên mạng
- Phân loại người tấn công
- Mô hình quản lý hệ thống IT của doanh nghiệp

Nội Dung

3

9/16/2025

- **Bảo mật thông tin là gì**
- Những thách thức trong bảo mật thông tin
- Những dạng tấn công cơ bản trên mạng
- Phân loại người tấn công
- Mô hình quản lý hệ thống IT của doanh nghiệp

Bảo Mật Thông Tin Là Gì

Những đặc điểm của thông tin

4

9/16/2025

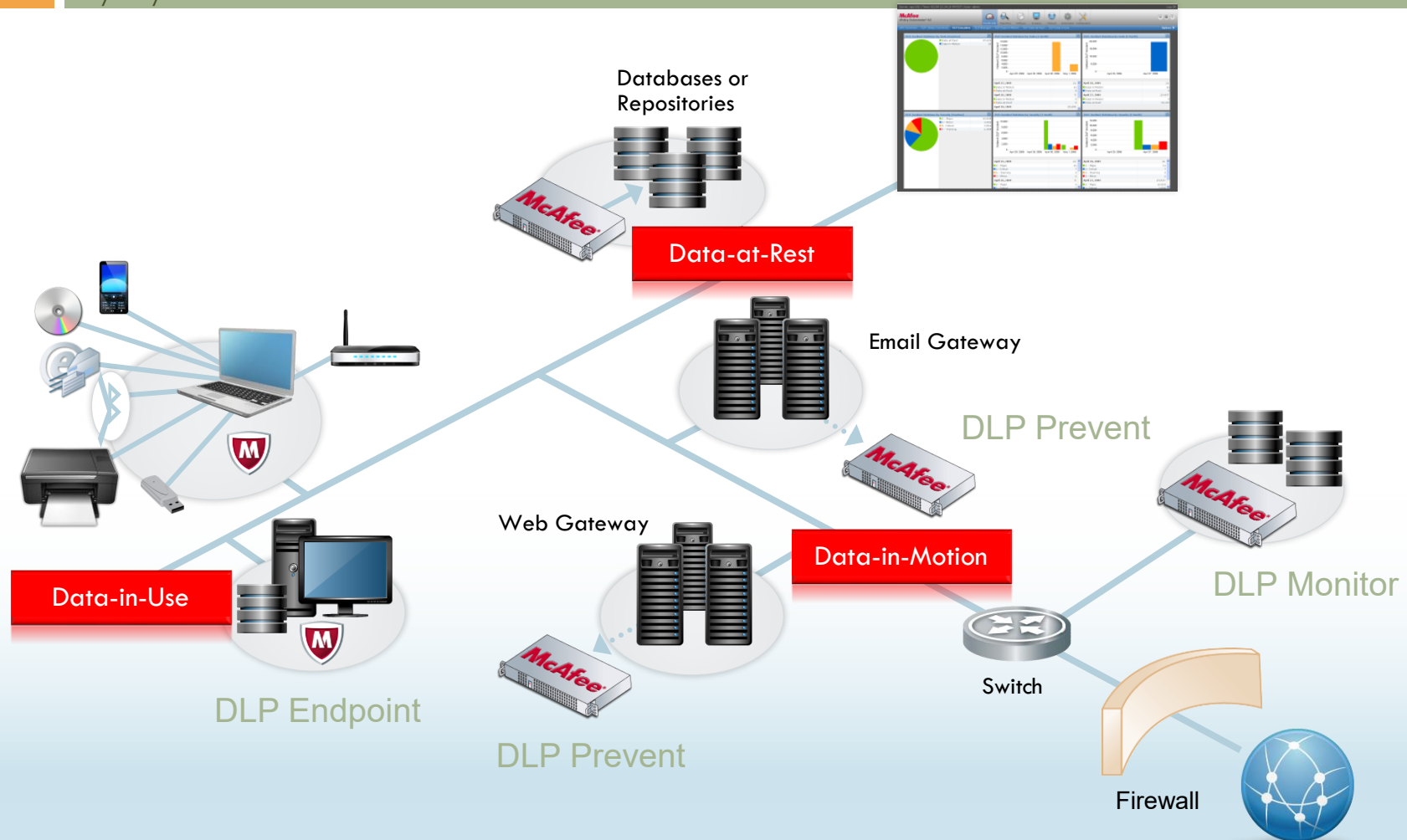


Bảo Mật Thông Tin Là Gì

Những trạng thái của thông tin

5

9/16/2025



Bảo Mật Thông Tin Là Gì

Những trạng thái của thông tin - tt

6

9/16/2025



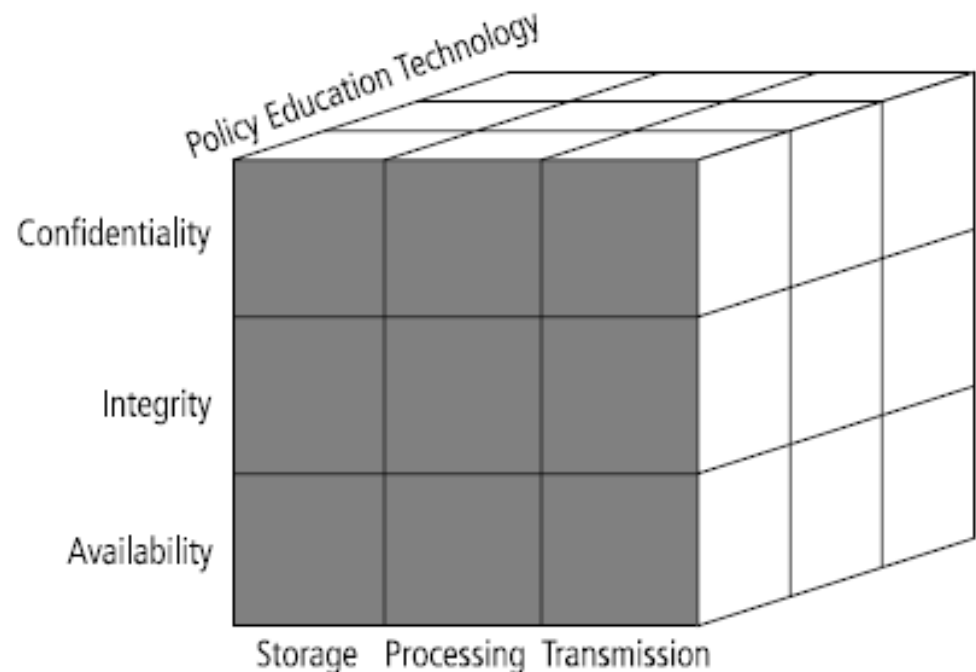
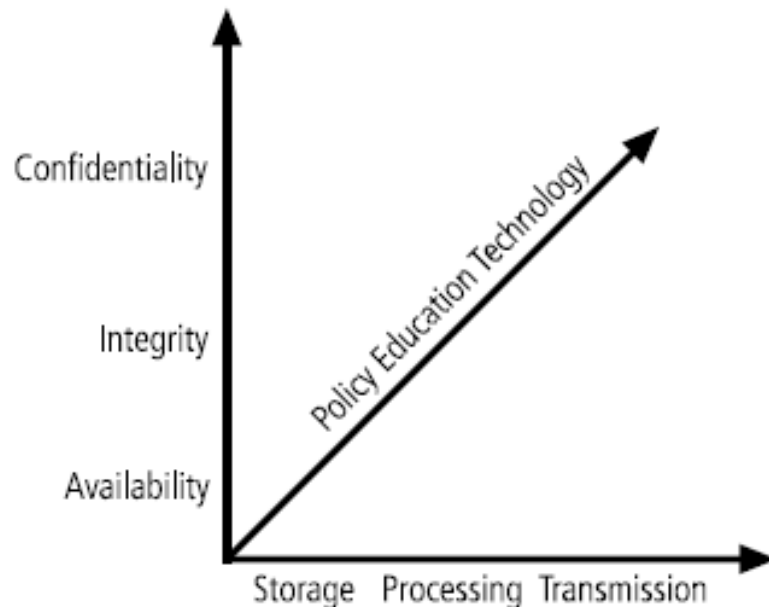
Bảo Mật Thông Tin Là Gì

Khái niệm

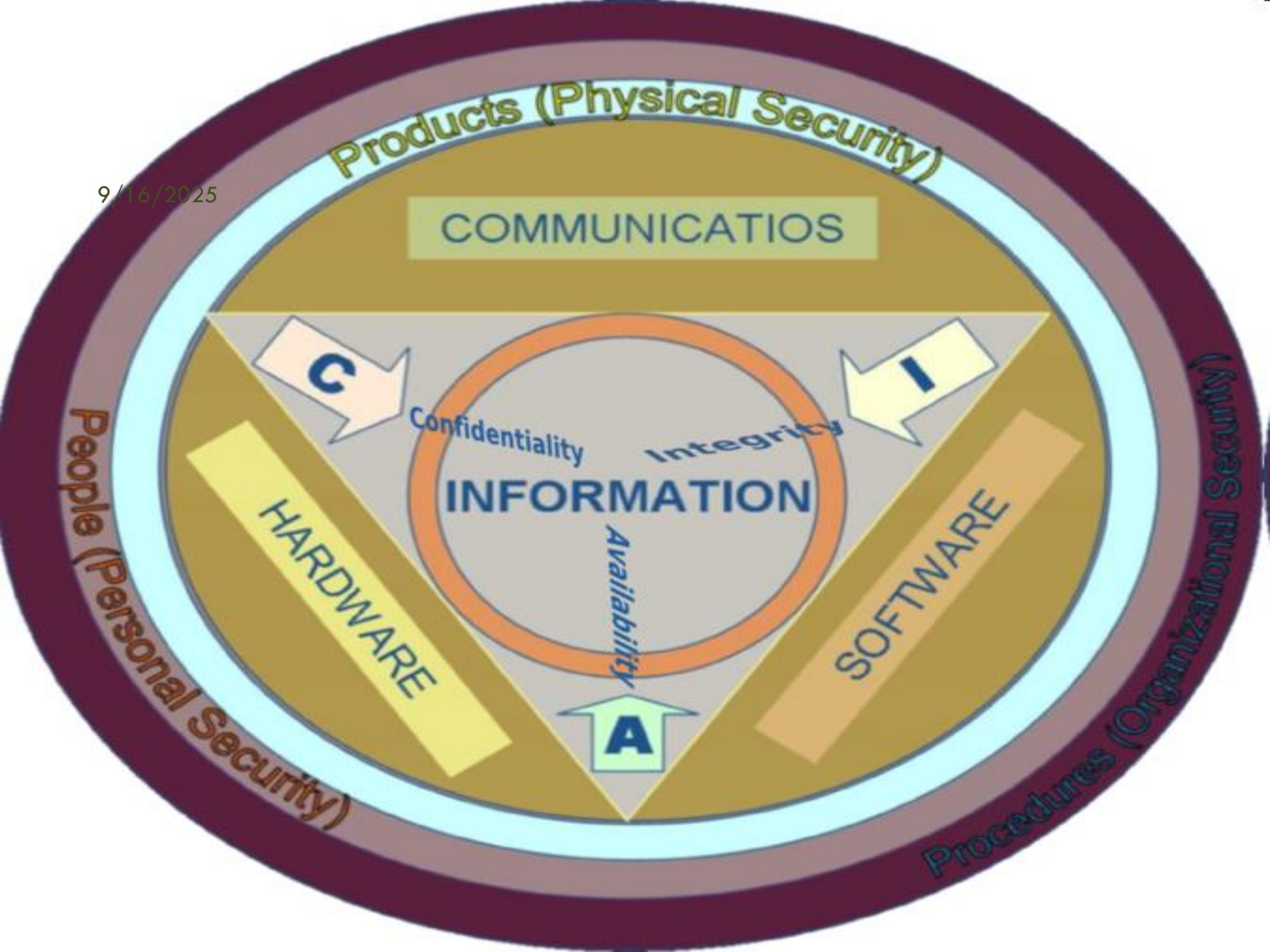
7

9/16/2025

- Bảo mật thông tin là đảm bảo **tính bảo mật, tính toàn vẹn** và **tính sẵn sàng** của thông tin trên các thiết bị lưu trữ, trong quá trình sử dụng và truyền thông.



9/16/2025





People



Hardware



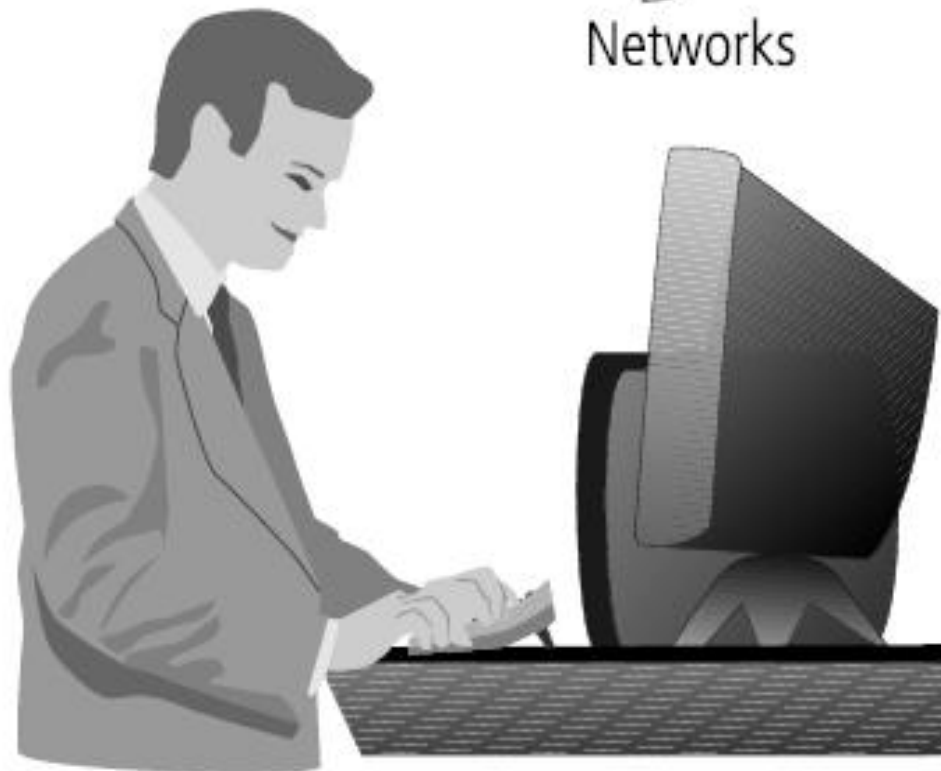
Networks



Software



Procedures



Data

Nội Dung

10

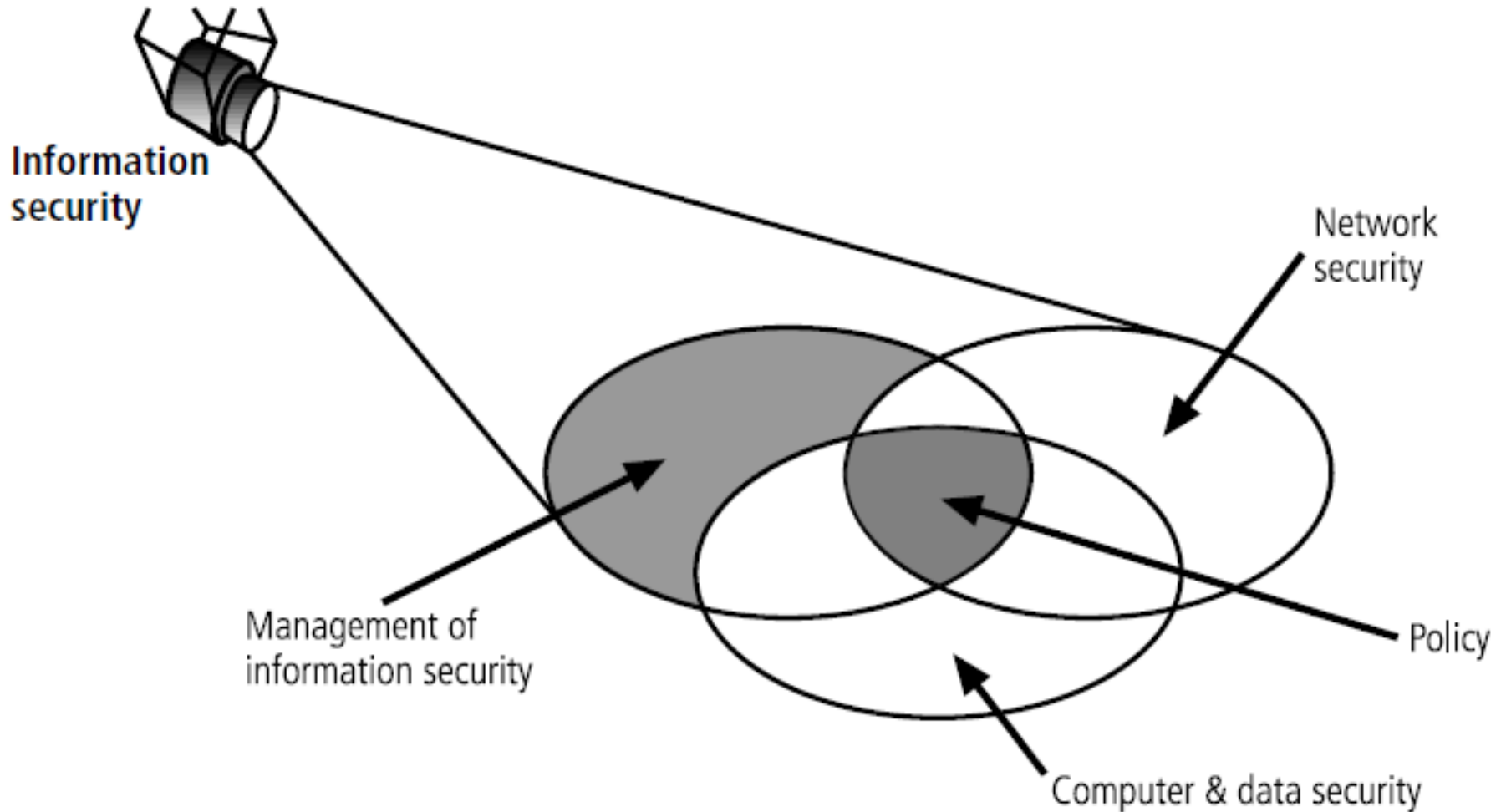
9/16/2025

- Bảo mật thông tin là gì
- **Những thách thức trong bảo mật thông tin**
- Những dạng tấn công cơ bản trên mạng
- Phân loại người tấn công
- Mô hình quản lý hệ thống IT của doanh nghiệp

Những Thách Thức Trong Bảo Mật Thông Tin

11

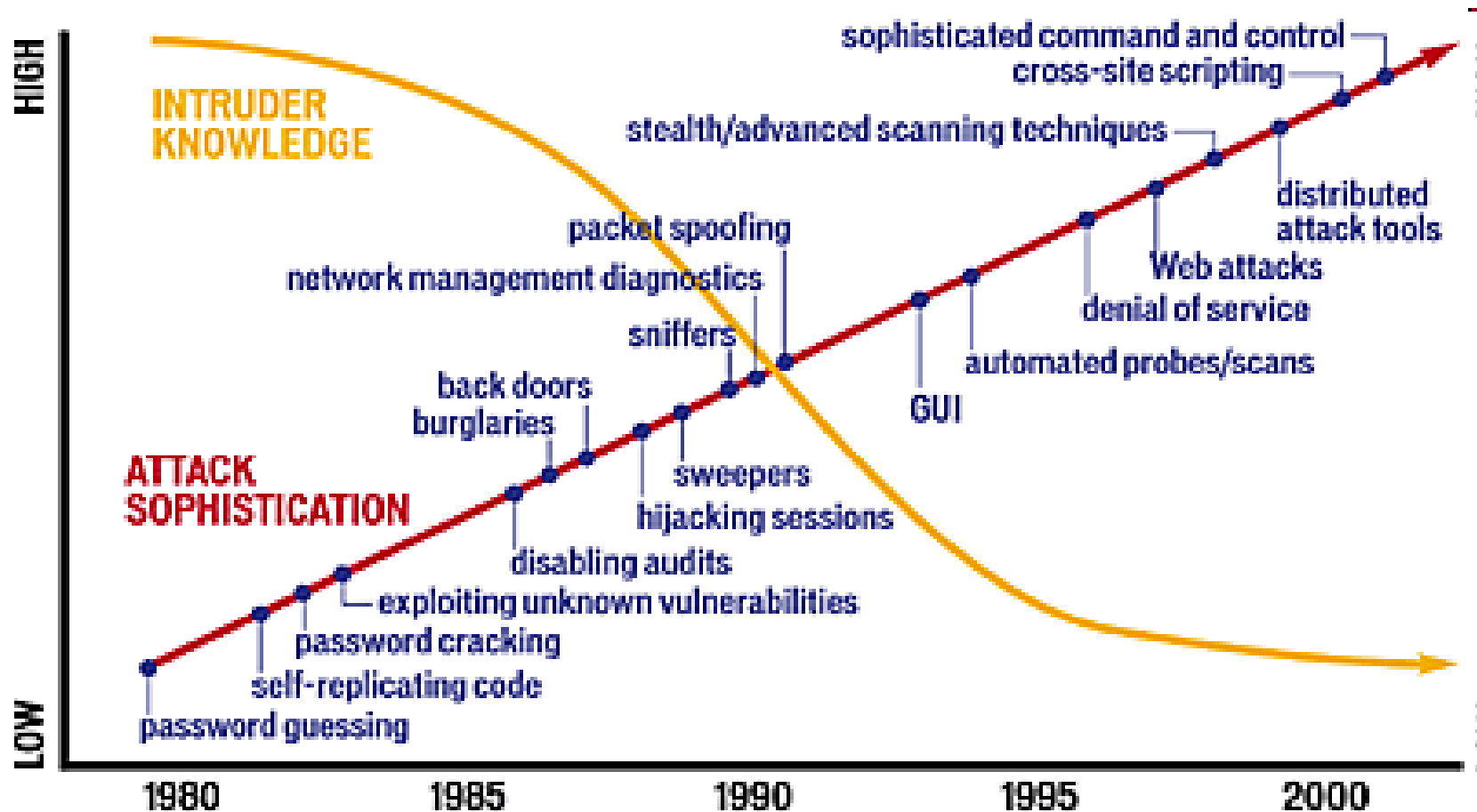
9/16/2025



Những Thách Thức Trong Bảo Mật Thông Tin - tt

12

9/16/2025



Những Thách Thức Trong Bảo Mật Thông Tin - tt

13

9/16/2025

- Tính sẵn sàng của dữ liệu
 - Tấn công Denial of Service (DoS)
 - Tấn công Distributed Denial of Service (DDoS)
 - Hệ thống ngưng hoạt động (System fail)
 - Rớt mạng (Network fail)
 - Cấu trúc dữ liệu bị phá hủy (malicious)

Những Thách Thức Trong Bảo Mật Thông Tin - tt

14

9/16/2025

- Tính toàn vẹn của dữ liệu
 - Man in the middle
 - SQL Injection
 - Buffer Overload
 - Malicious code
 - Employee
 - Thuật toán bảo vệ tính toàn vẹn yếu

Nội Dung

15

9/16/2025

- Bảo mật thông tin là gì
- Những thách thức trong bảo mật thông tin
- **Những dạng tấn công cơ bản trên mạng**
- Phân loại người tấn công
- Mô hình quản lý hệ thống IT của doanh nghiệp

Những Dạng Tấn Công Cơ Bản

16

9/16/2025

- Eavesdropping (Nghe lén)
- Data Modification (Thay đổi dữ liệu)
- Identity Spoofing (Giả mạo danh tính)
- Password-Based Attacks
- Denial-of-Service Attack (tấn công từ chối dịch vụ)
- Malicious Software

Những Dạng Tấn Công Cơ Bản

Eavesdropping (Nghe lén)

17

9/16/2025



Những Dạng Tấn Công Cơ Bản

Eavesdropping (Nghe lén)

18

9/16/2025

- Nghe trộm là một phương pháp cũ nhưng hiệu quả.
- Sử dụng một thiết bị mạng chuyên dụng hay một chương trình ứng dụng (Tcpdump, Ethereal, Wireshark...) để giám sát lưu lượng mạng.
- Cách hạn chế nghe lén:
 - Kiểm soát truy cập mạng
 - Mã hóa dữ liệu khi truyền trên mạng

Những Dạng Tấn Công Cơ Bản

Eavesdropping (Nghe lén)

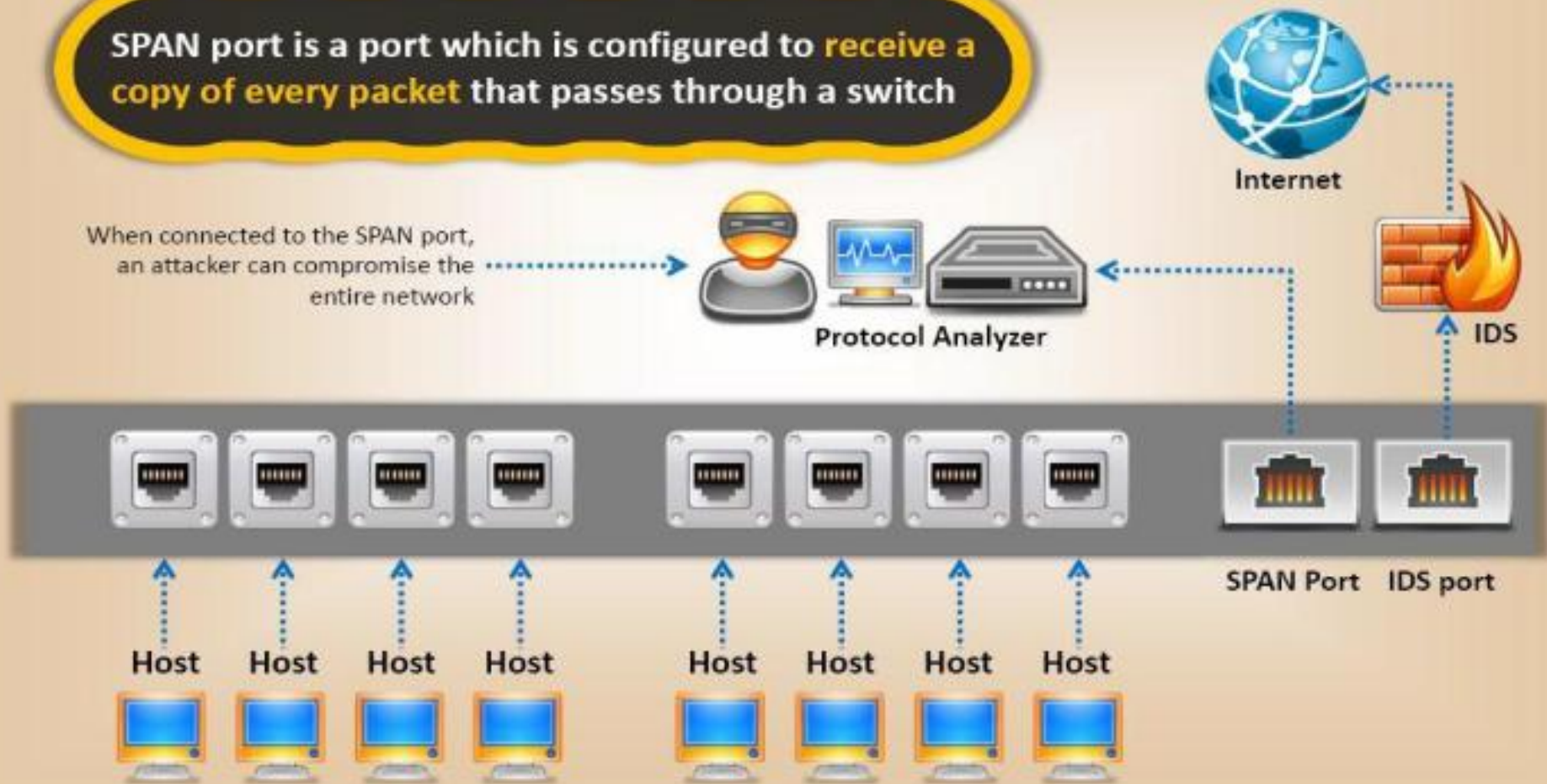
19

9/16/2025

SPAN Port

SPAN port is a port which is configured to **receive a copy of every packet** that passes through a switch

When connected to the SPAN port, an attacker can compromise the entire network



Những Dạng Tấn Công Cơ Bản

Eavesdropping (Nghe lén)

20

9/16/2025

Follow TCP Stream

Stream Content

220 (vsFTPD 2.0.7)
USER anonymous
331 Please specify the password.
PASS 12345
230 Login successful.

211-Features:
EPRT
EPSV
MDTM
PASV
REST STREAM
SIZE
TVFS
UTF8
211 End

200 Always in UTF8 mode.

257 "/"

200 switching to ASCII mode.

227 Entering Passive Mode (195,189,143,122,119,75)

150 Here comes the directory listing.
226 Directory send OK.

End Save As Print Entire conversation (431 bytes)

Help

Realtek RTL 8149/8110 Family Gigabit Ethernet NIC (Microsoft's Packet Scheduler) - Wireshark

File Edit View Go Capture Analysis Statistics Telephony Tools Help

Filter: tcp.stream eq 45 * Export... Clear Apply

No.	Time	Source	Destination	Protocol	Info
4884	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: 230 Login successful.
4885	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: PASS
4927	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: 211-Features:
4928	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: EPRT
4929	2010-	192.168.168.7	pl3-01.opera.com	TCP	ft-role > ftp [ACK] Seq=49 Ack=100 Win=65436 Len=0
4930	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: EPSV
4931	2010-	pl3-01.opera.com	192.168.168.7	FTP	Request: MDTM
4932	2010-	192.168.168.7	pl3-01.opera.com	TCP	ft-role > ftp [ACK] Seq=49 Ack=114 Win=65422 Len=0
4933	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: PASV
4978	2010-	pl3-01.opera.com	192.168.168.7	FTP	Request: REST STREAM
4979	2010-	192.168.168.7	pl3-01.opera.com	TCP	ft-role > ftp [ACK] Seq=49 Ack=165 Win=65371 Len=0
4980	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: OPTS UTF8 ON
5040	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: 200 Always in UTF8 mode.
5041	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: PWD
5143	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: 257 "/"
5179	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: TYPE A
5249	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: 200 switching to ASCII mode.
5250	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: PASV
5320	2010-	pl3-01.opera.com	192.168.168.7	FTP	Response: 227 entering Passive Mode (195,189,143,122,119,75)
5322	2010-	192.168.168.7	pl3-01.opera.com	FTP	Request: LIST

Frame 4884 (77 bytes on wire (77 bytes captured))
Ethernet II, Src: sonifowl_3f1e1a0 (00:00:00:3f:1e:1a:0), Dst: a7fegro_2212d15f (00:05:11:22:1d:15:f)
Internet Protocol, Src: pl3-01.opera.com (195.189.143.122), Dst: 192.168.168.7 (192.168.168.7)
Transmission Control Protocol, Src Port: ftp (21), Dst Port: ft-role (2429), Seq: 55, Ack: 43, Len: 23
File Transfer Protocol (FTP)

0000 00 25 11 22 2d 3f 00 06 b1 3f 1e 40 08 00 43 00 .X.11...?....E.
0010 00 3f 94 a7 40 00 32 06 f7 09 c3 bd 8f 7a c0 48 .?..9;2.....Z..
0020 a8 07 00 15 09 7d c8 3c f0 ff ba fa ad 45 50 10).c.....EP.
0030 16 00 ca 75 00 00 32 33 30 20 4c 0f 67 09 0e 20 ...u..?o Login
0040 71 75 63 63 65 71 73 66 75 6c 2e 0d 0a success! u!...

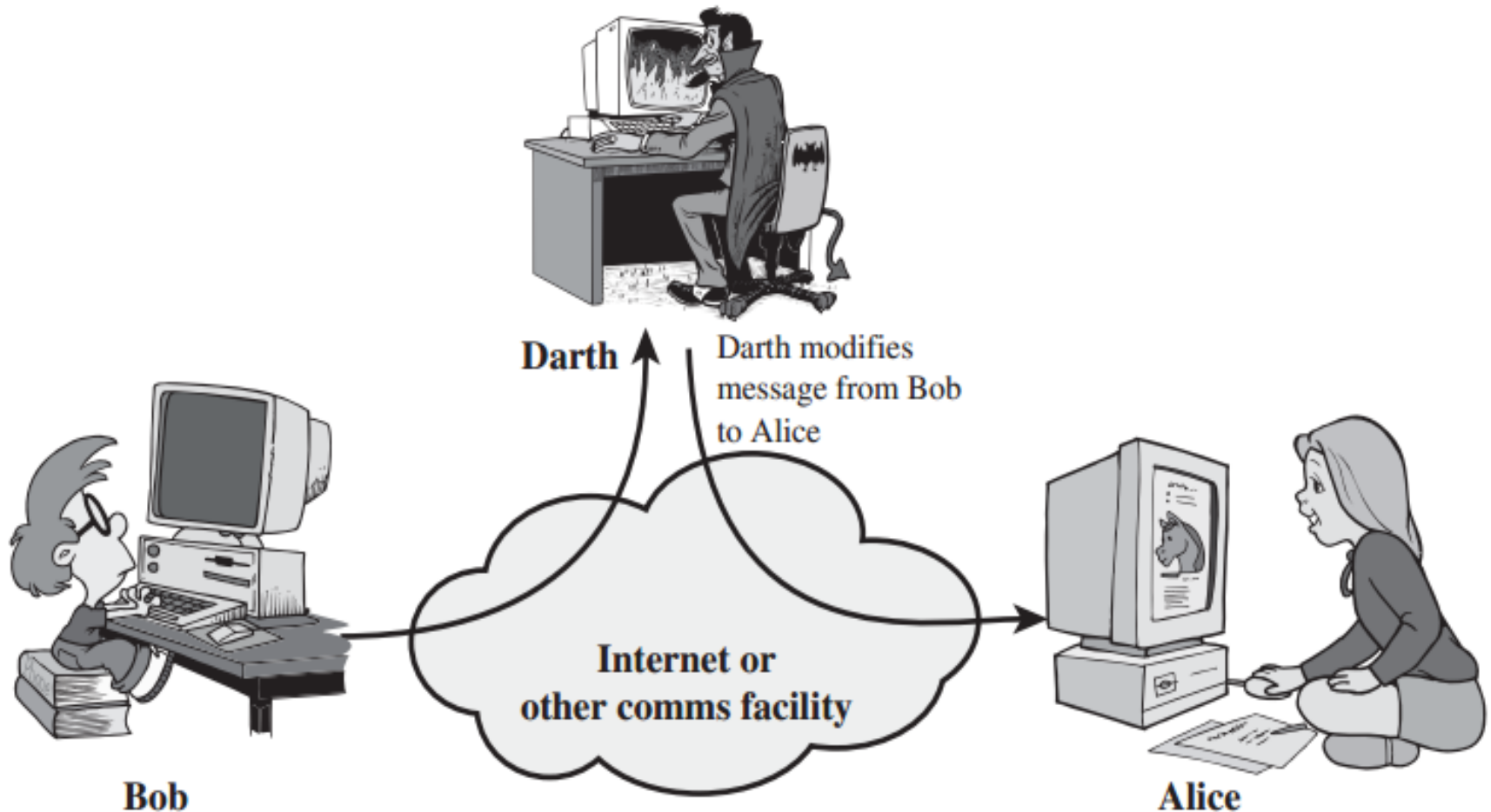
File: C:\DOCUME~1\PA\LOCAL5-1\Temp\... Packets: 1960 Displayed: 33 Marked: 0 Dropped: 0 Profile: Default

Những Dạng Tấn Công Cơ Bản

Data Modification (Thay đổi dữ liệu)

21

9/16/2025



Những Dạng Tấn Công Cơ Bản

Data Modification (Thay đổi dữ liệu)

22

9/16/2025

- Can thiệp vào phiên làm việc giữa người gửi và người nhận.
- Giả mạo
- Cách hạn chế:
 - Xác thực
 - Hàm băm (đảm bảo tính toàn vẹn)

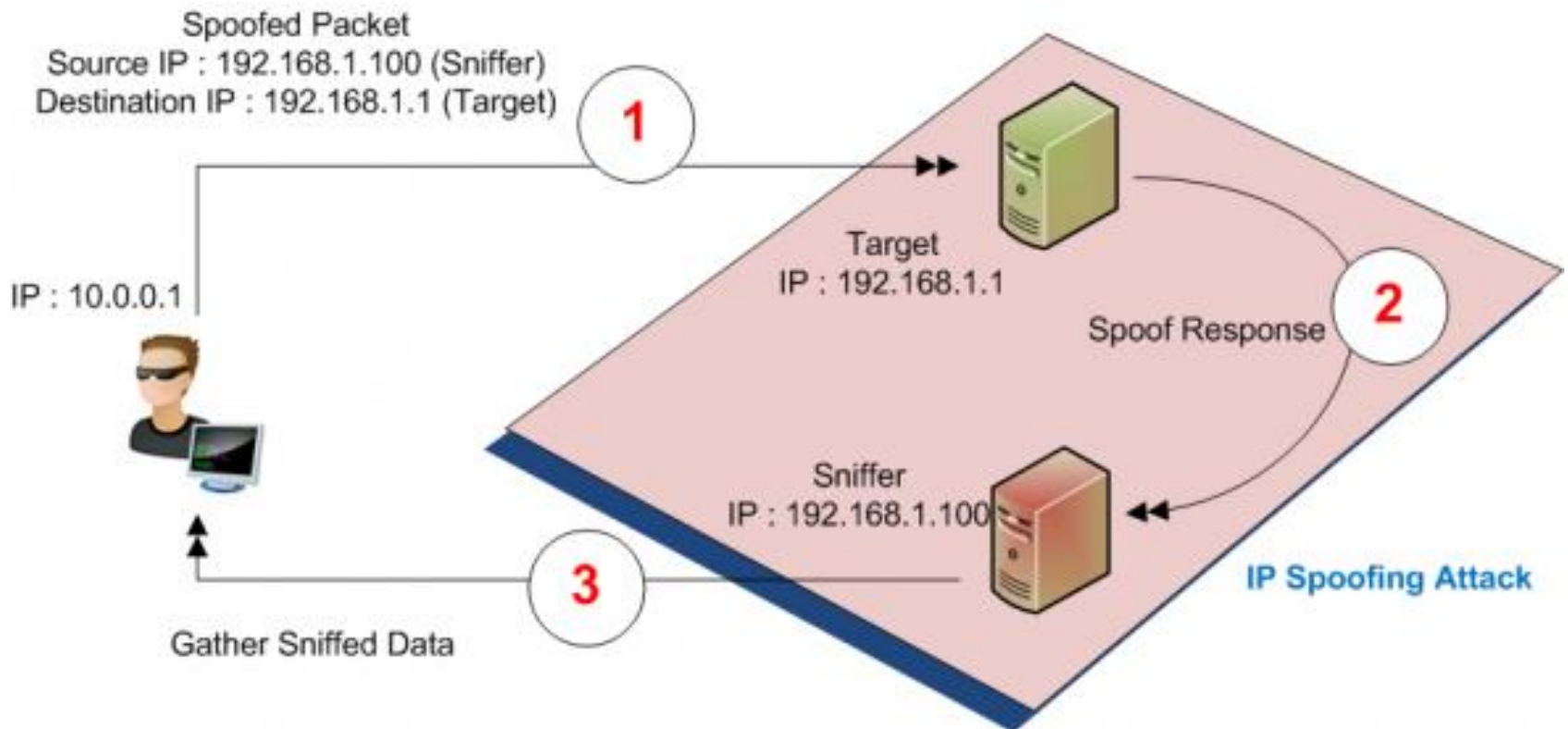
Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

23

9/16/2025

- Người tấn công giả mạo nạn nhân để lừa người giao dịch với nạn nhân



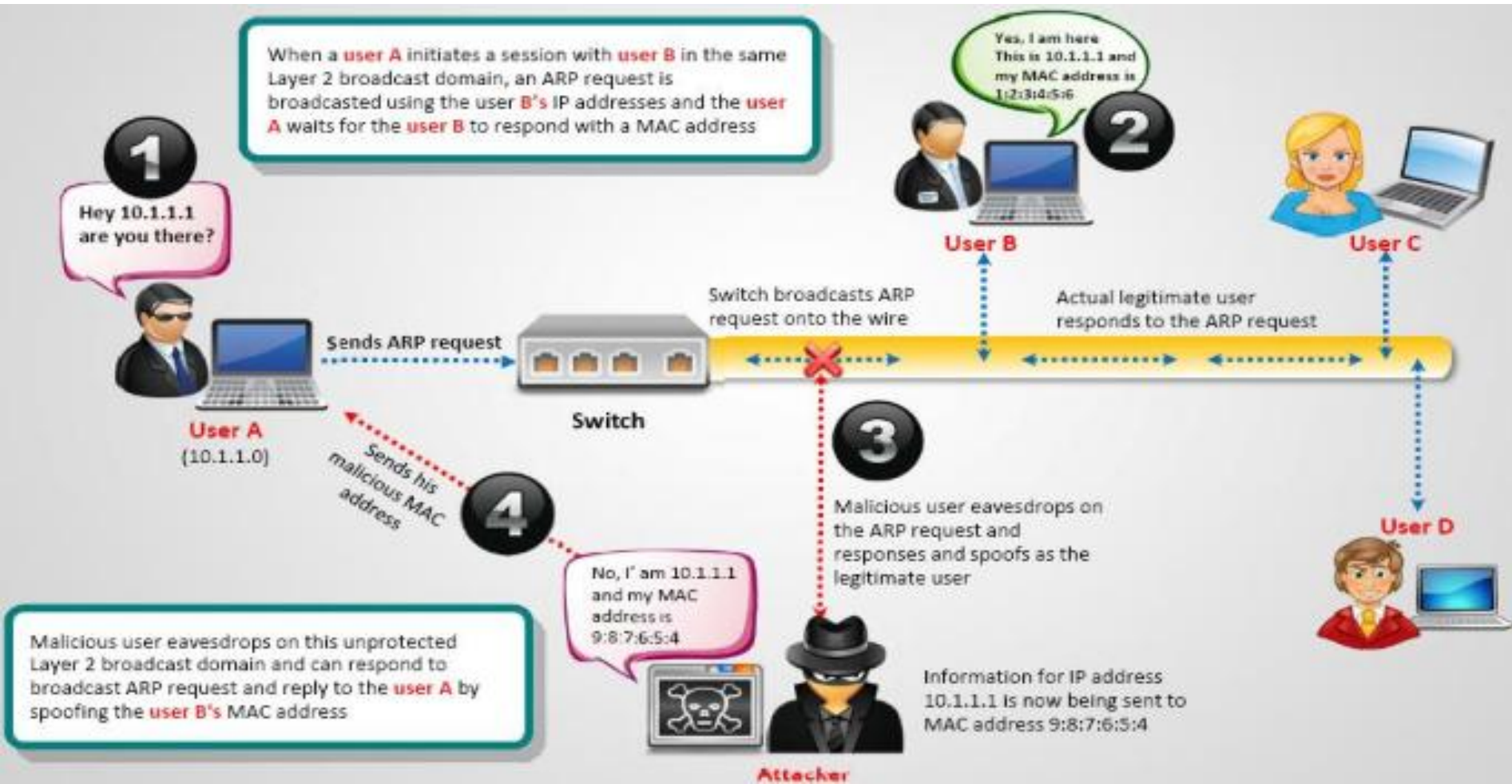
Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

24

9/16/2025

➤ ARP Spoofing



Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

25

9/16/2025

- Những mối đe dọa ARP Spoofing gây ra
 - DoS
 - Data interception
 - Stealing Password

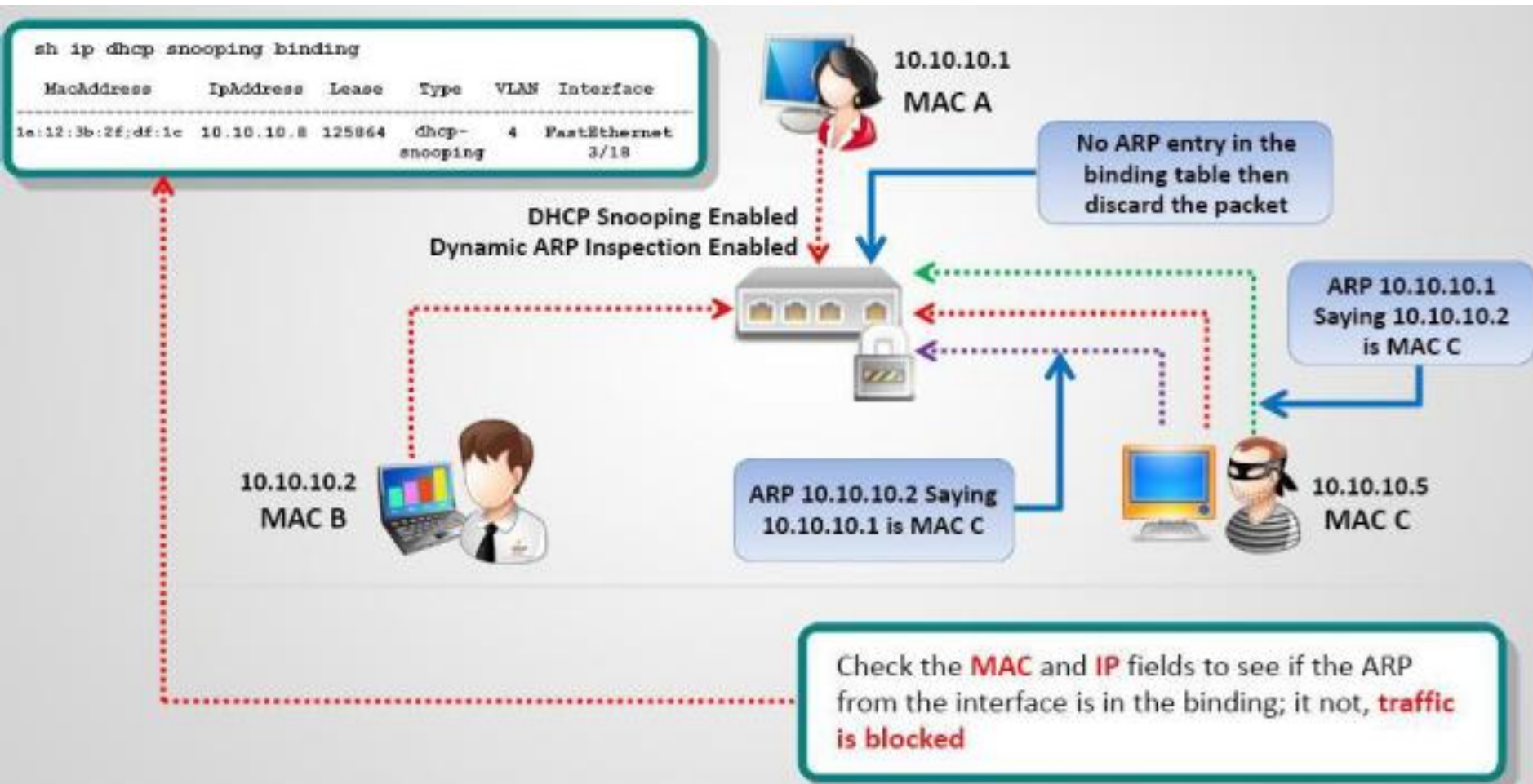
Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

26

9/16/2025

➤ Cách hạn chế



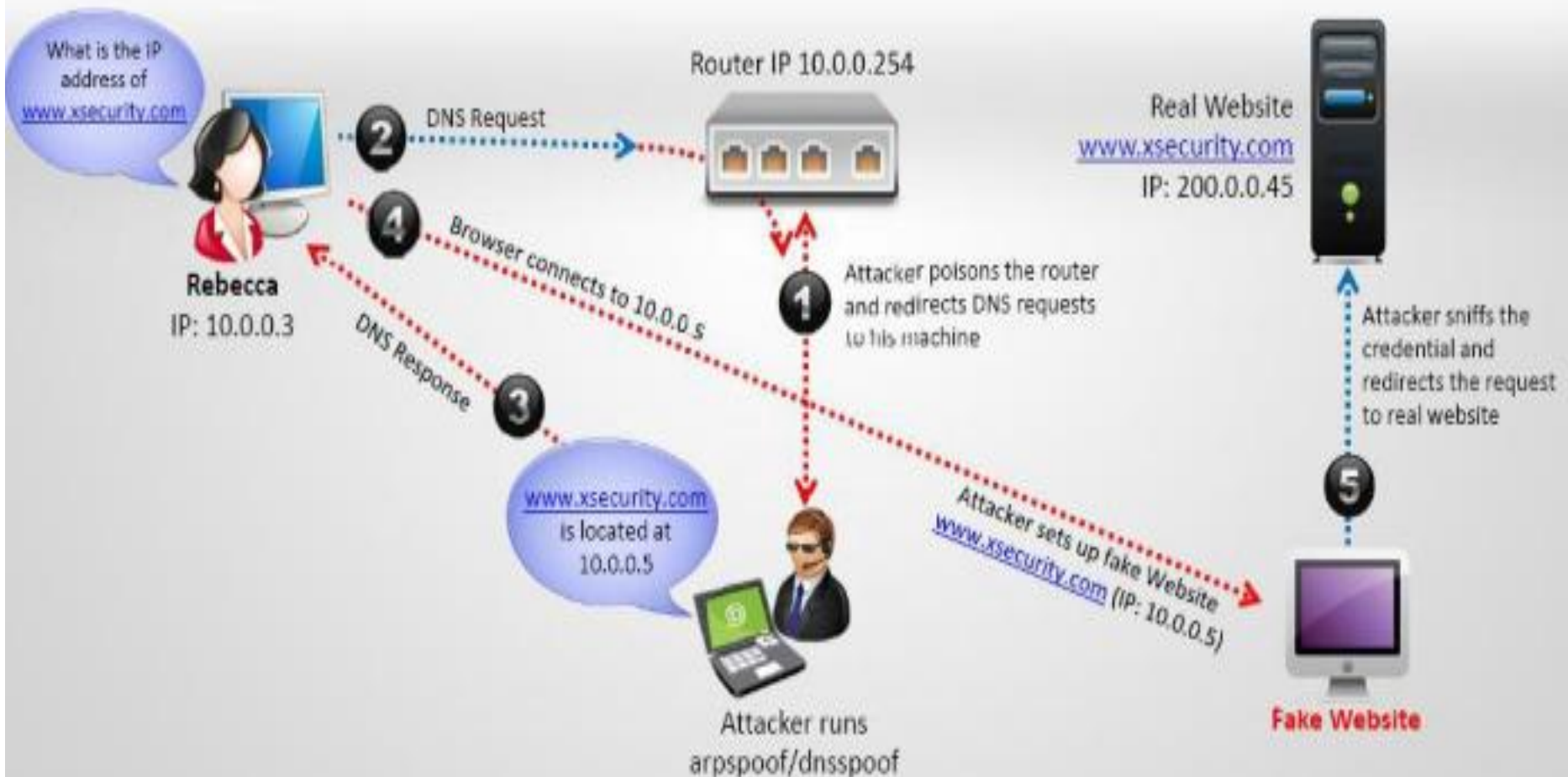
Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

27

9/16/2025

➤ DNS Spoofing (LAN)



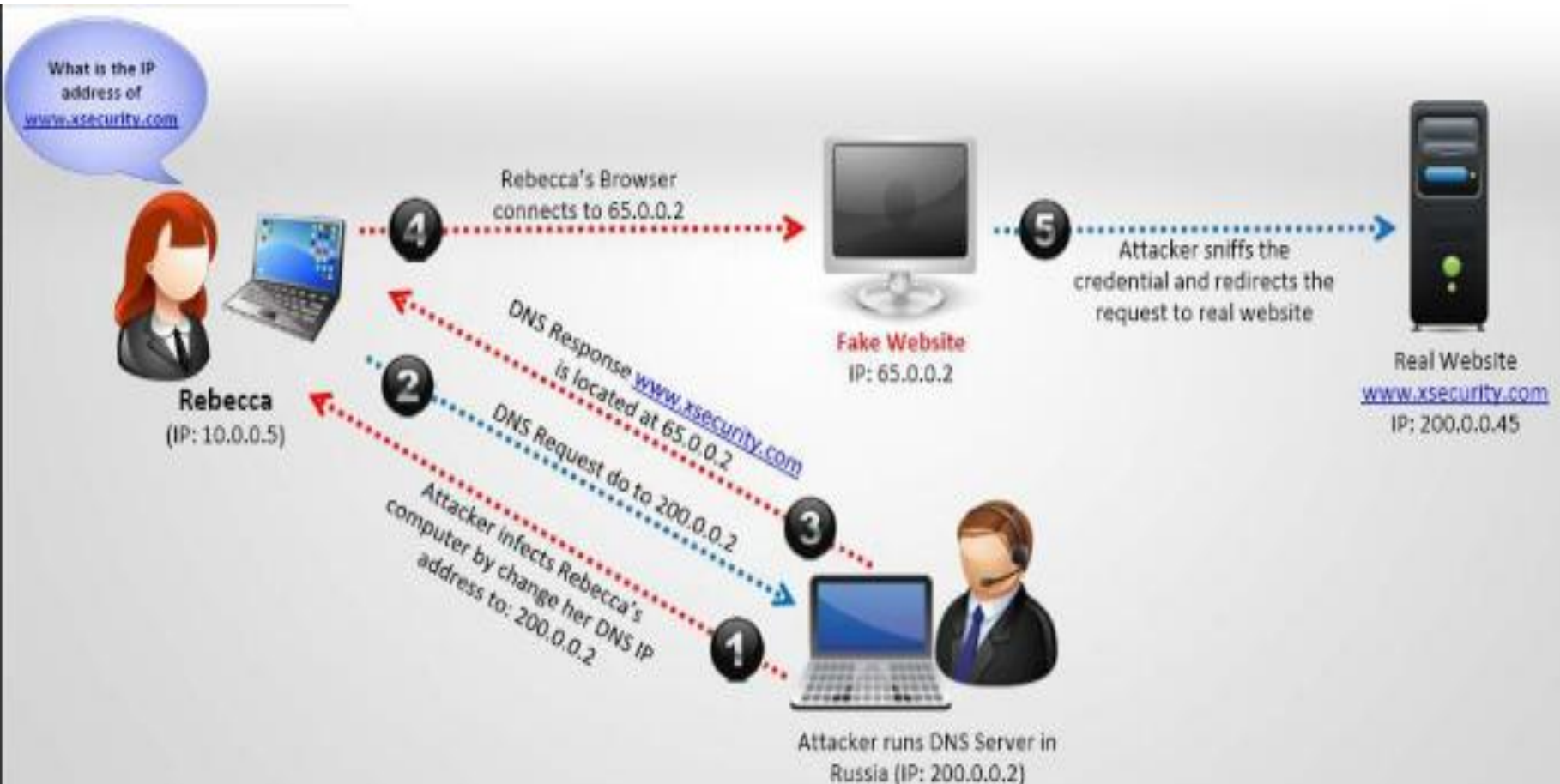
Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

28

9/16/2025

➤ DNS Spoofing (Trojan)



Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

29

9/16/2025

➤ DNS Spoofing (thay đổi cấu hình Proxy client)



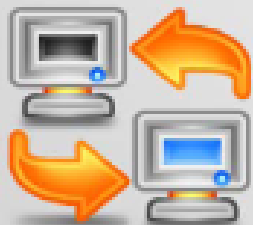
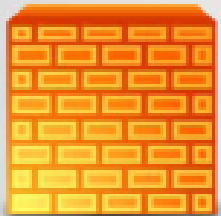
Những Dạng Tấn Công Cơ Bản

Identity Spoofing (Giả mạo danh tính)

30

9/16/2025

➤ Cách hạn chế DNS Spoofing



01

Resolve all DNS queries to local DNS server

02

Block DNS requests from going to external servers

03

Implement DNSSEC

04

Configure DNS resolver to use a new random source port from its available range for each outgoing query

05

Configure firewall to restrict external DNS lookup

06

Restrict DNS recursing service, either full or partial, to authorized users

07

Use DNS Non-Existent Domain (NXDOMAIN) Rate Limiting

Những Dạng Tấn Công Cơ Bản

Password-Based Attacks

31

9/16/2025

- Cơ chế chứng thực được sử dụng rộng rãi nhất là dùng username và password.
- Các phương pháp thông dụng để tấn công password:
 - Crack Password
 - Password attacks

Password Cracking Techniques

The program tries every combination of characters until the password is broken

It is the combination of both brute force attack and the dictionary attack



Dictionary Attacks

Brute Forcing Attacks

Hybrid Attack

Syllable Attack

Rule-based Attack

A dictionary file is loaded into the cracking application that runs against user accounts

It works like a dictionary attack, but adds some numbers and symbols to the words from the dictionary and tries to crack the password

This attack is used when the attacker gets some information about the password

Types of Password Attacks



Passive Online Attacks: **Wire Sniffing**

Attackers run packet sniffer tools on the LAN to access and record the raw network traffic



The captured data may include passwords sent to remote systems during Telnet, FTP, rlogin sessions, and electronic mail sent and received

Hard to Perpetrate

How effective is the attack?

Computationally Complex

Attacker must sniff the network

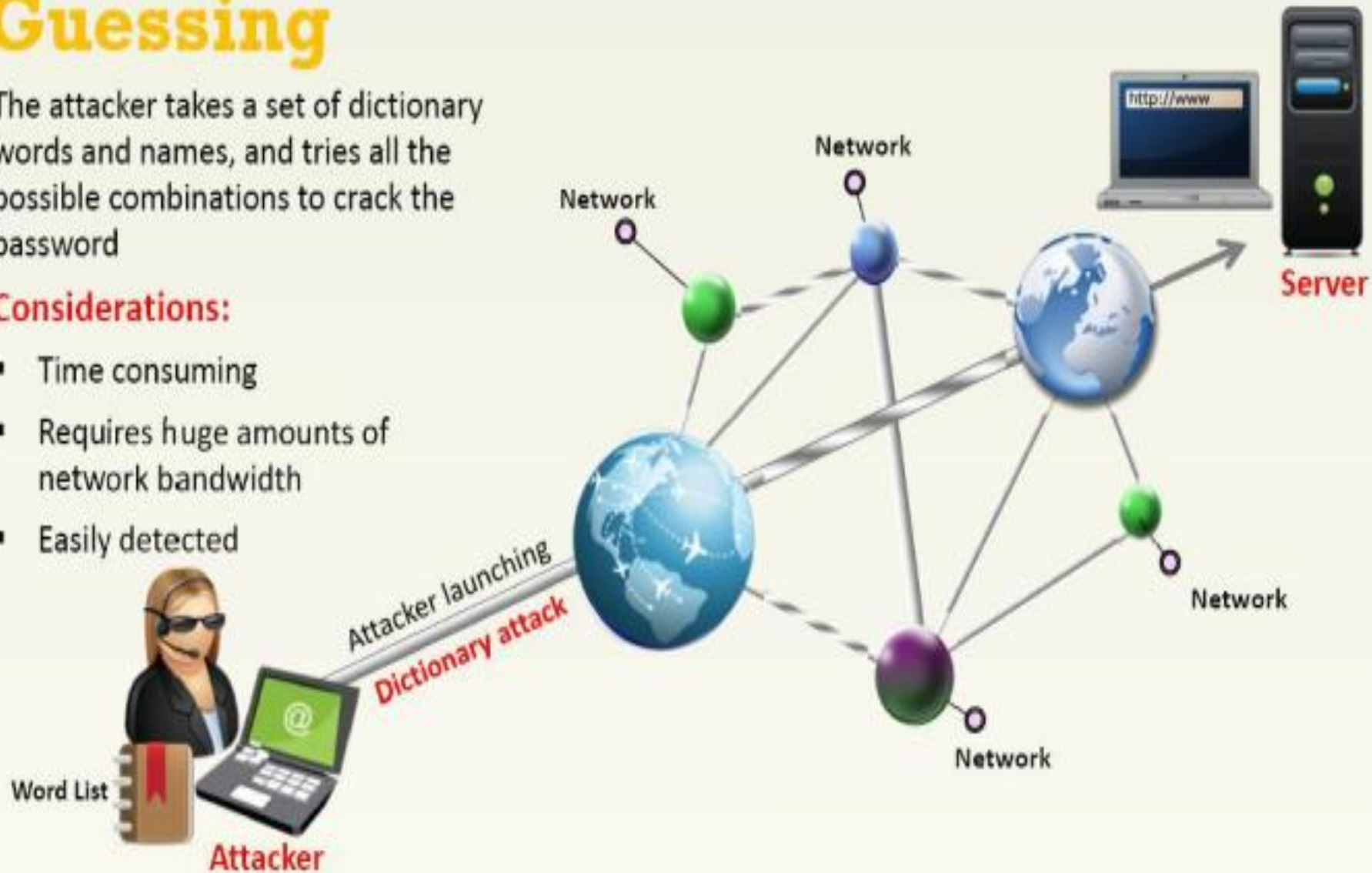
Tools Available

Active Online Attack: Password Guessing

The attacker takes a set of dictionary words and names, and tries all the possible combinations to crack the password

Considerations:

- Time consuming
- Requires huge amounts of network bandwidth
- Easily detected



Những Dạng Tấn Công Cơ Bản

Password-Based Attacks

36

9/16/2025

- Theo CBSNews, 10 passwords thông dụng nhất thế giới 2013:

- 1. 123456
- 2. password
- 3. 12345678
- 4. qwerty
- 5. abc123

- 6. 123456789
- 7. 111111
- 8. 1234567
- 9. iloveyou
- 10. adobe123

Active Online Attack:

Trojan/Spyware/Keylogger

A Keylogger is a program that runs in the background and allows remote attackers to **record every keystroke**

Keylogger

Spyware

Spyware is a type of malware that allows attackers to **secretly** gather information about a person or organization

Trojan

With the help of a Trojan, an attacker gets access to the **stored passwords** in the attacked computer and is able to read personal documents, delete files, and display pictures



Passive Online Attack: **Man-in-the-Middle** and **Replay Attack**



- ❖ In a MITM attack, the attacker acquires **access** to the communication channels between victim and server to extract the information
- ❖ In a replay attack, packets and authentication tokens are captured using a **sniffer**. After the relevant info is extracted, the tokens are placed back on the network to gain access

Considerations:

1. Relatively hard to perpetrate
2. Must be trusted by one or both sides
3. Can sometimes be broken by invalidating traffic

Những Dạng Tấn Công Cơ Bản

Password-Based Attacks

39

9/16/2025

➤ Social engineering

- Là phương pháp sử dụng các kỹ năng xã hội để ăn cắp thông tin mật của người khác.
 - Mạo danh (Impersonate)
 - Lừa đảo (Physing) qua email, websites...
 - Thu thập thông tin từ giấy tờ bị loại bỏ
 - Tạo trang web đăng nhập giả...

Những Dạng Tấn Công Cơ Bản

Denial-of-Service Attack

40

9/16/2025

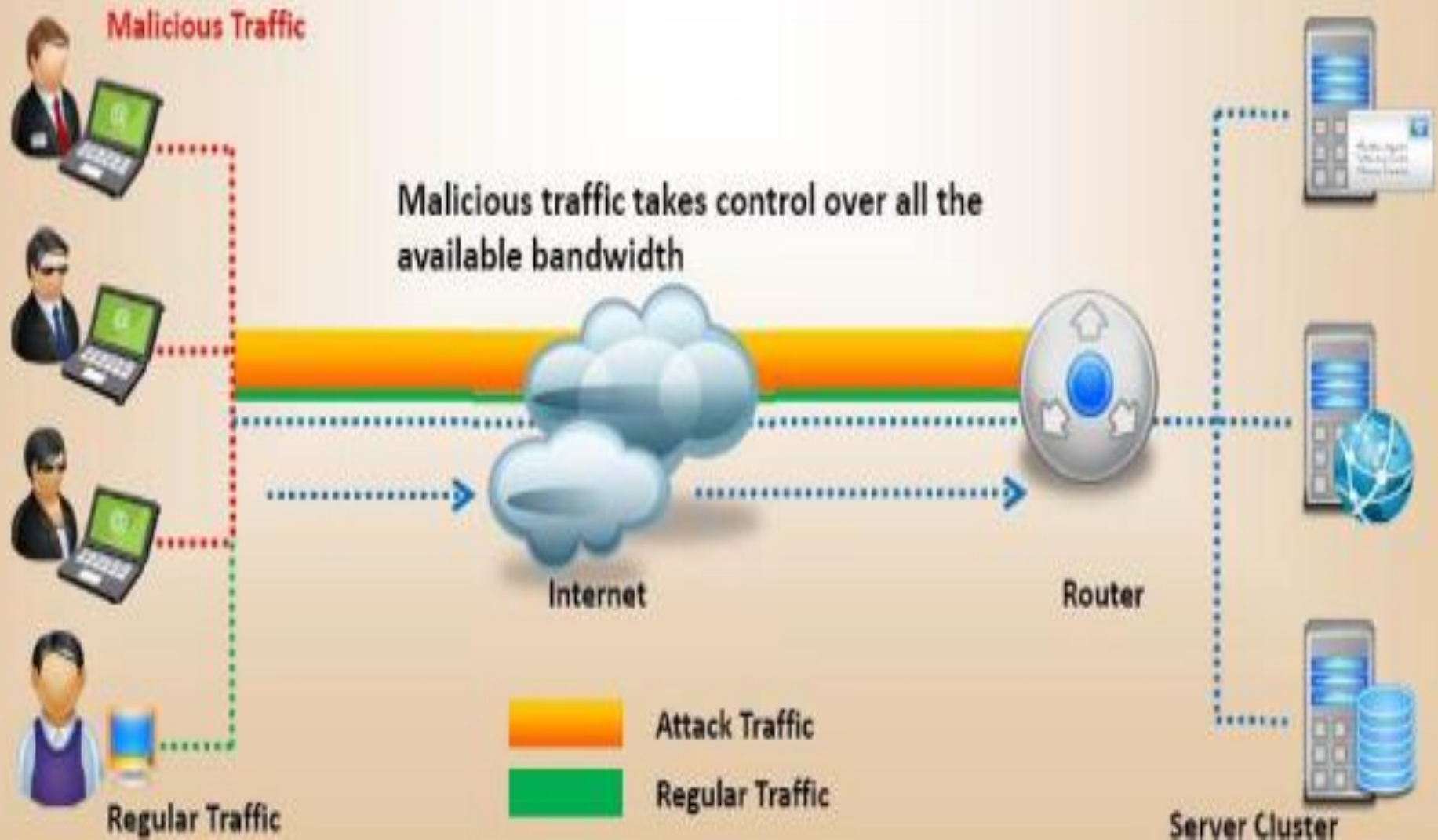
- Mục tiêu của cuộc tấn công từ chối dịch vụ là ngăn chặn người dùng hợp pháp sử dụng những dịch vụ mà họ thường nhận được từ các máy chủ.
- Buộc máy tính mục tiêu (máy chủ hoặc mạng) phải xử lý một số lượng lớn những yêu cầu vô dụng, hy vọng máy tính này sẽ tiêu thụ tất cả các nguồn tài nguyên quan trọng.
- Một cuộc tấn công từ chối dịch vụ có thể được phát sinh từ một máy tính duy nhất (DoS), hoặc từ một nhóm các máy tính phân bố trên mạng Internet (DDoS).

Những Dạng Tấn Công Cơ Bản

Denial-of-Service Attack

41

9/16/2025



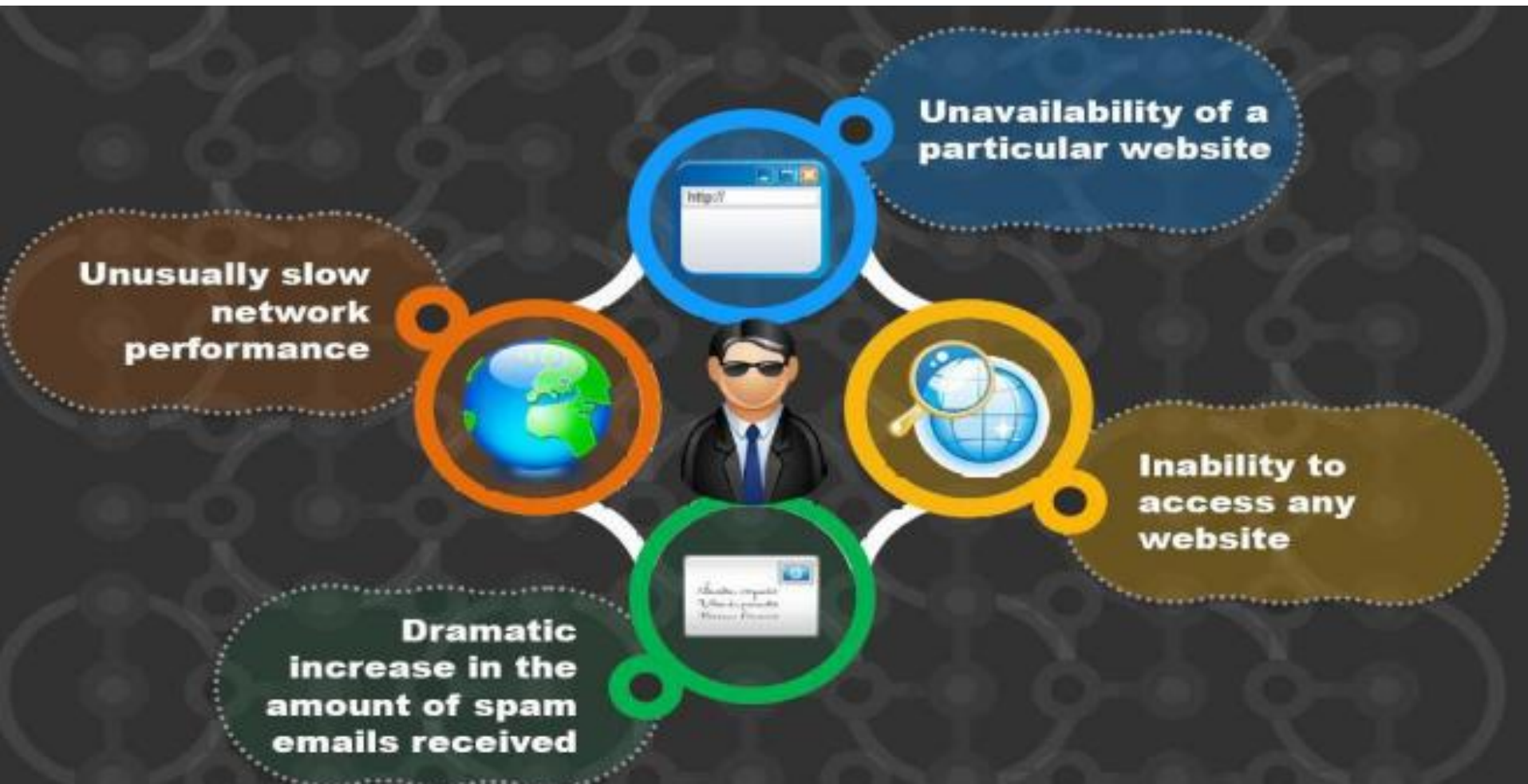
Những Dạng Tấn Công Cơ Bản

Denial-of-Service Attack

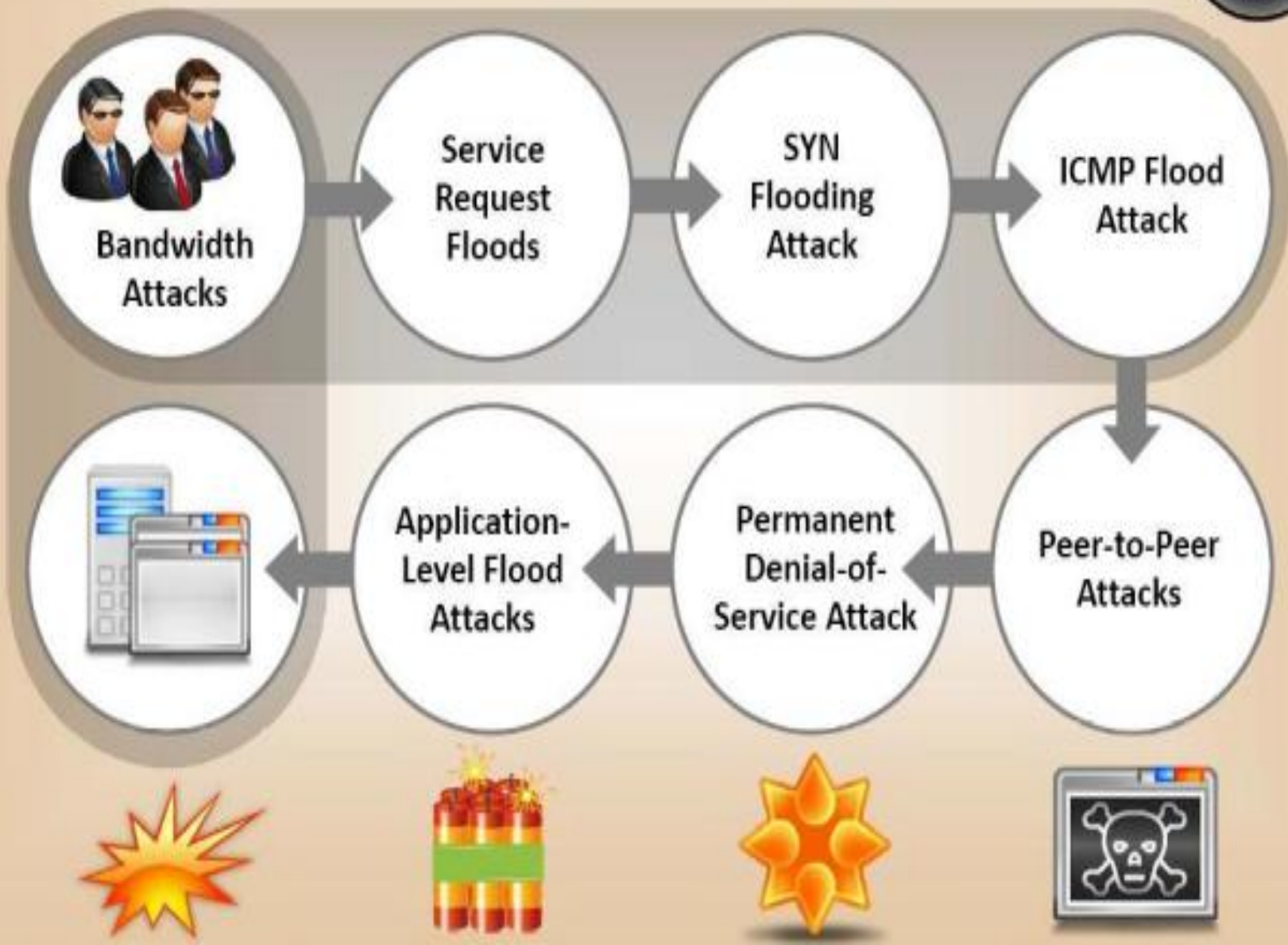
42

9/16/2025

➤ Những biểu hiện khi bị DoS



DoS Attack Techniques

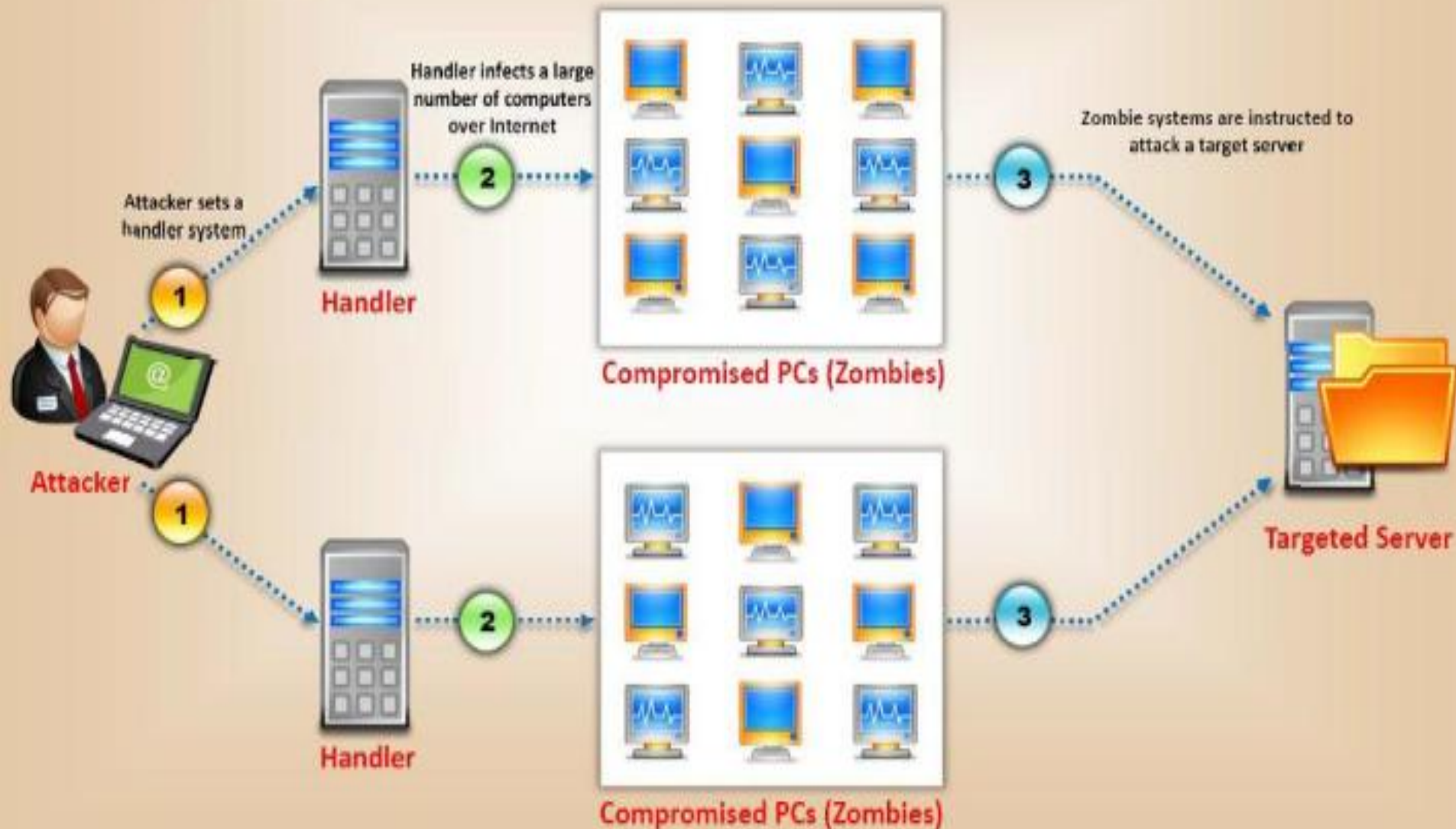


Những Dạng Tấn Công Cơ Bản

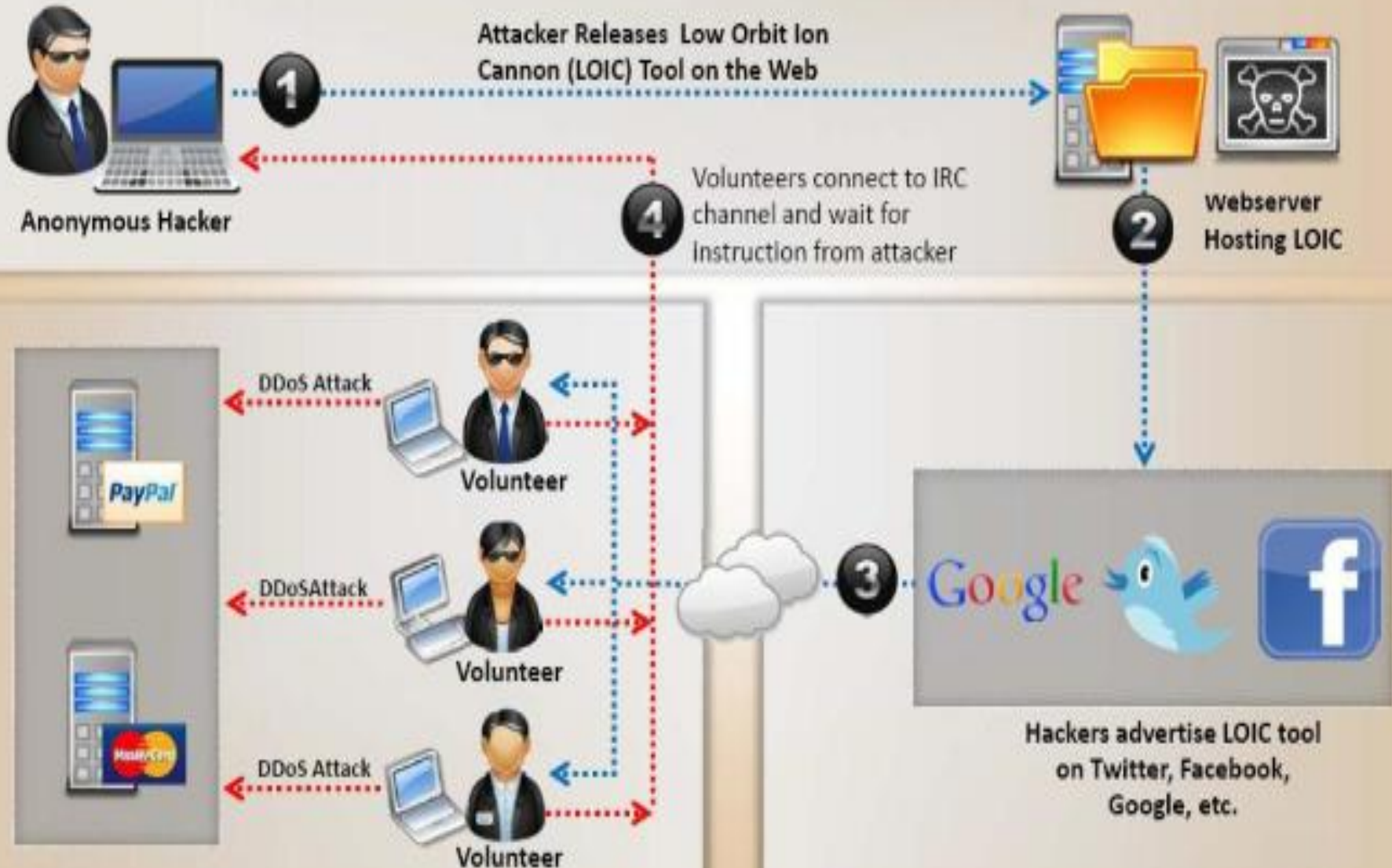
Distributed Denial-of-Service Attack

44

9/16/2025



DDoS Attack



Những Dạng Tấn Công Cơ Bản

Malicious Software

46

9/16/2025

- Virus
- Worms
- Trojan horses
- Backdoors
- Logic bombs
- Spyware

Những Dạng Tấn Công Cơ Bản

Malicious Software

47

9/16/2025

➤ Virus

- Là một phần mềm có thể sao chép chính nó. Nó không đứng một mình mà phải gắn vào một tập tin hoặc một chương trình khác.
- Khi một chương trình bị nhiễm virus máy tính được thực hiện hoặc một tập tin bị nhiễm được mở ra, loại virus chứa trong nó sẽ được thực thi.
- Khi thực hiện, virus có thể làm hại máy tính và sao chép chính nó để lây nhiễm sang máy khác trong hệ thống.

Những Dạng Tấn Công Cơ Bản

Malicious Software

48

9/16/2025

➤ Worms

- Cũng là một chương trình có thể tự sao chép chính nó. Nhưng không giống như virus, Worm là một chương trình đứng một mình (stand alone program). Nói cách khác là nó không cần vật chủ để ký sinh
- Một Worm có thể tự thực thi tại bất kỳ thời điểm nào nó muốn
- Khi thực thi, Worm có thể gây nguy hiểm cho hệ thống nơi nó thường trú hoặc tái sinh chính nó trên các hệ thống qua mạng

Những Dạng Tấn Công Cơ Bản

Malicious Software

49

9/16/2025

➤ Trojan horses

- Thường nguy trang mình kèm theo những chương trình ứng dụng thông thường và vô hại như trò chơi hoặc những công cụ miễn phí để người dùng tải về máy.
- Trojan không tự sinh sản như virus hay worm và chỉ thực hiện khi người dùng chạy chương trình có đính kèm Trojan.
- Chức năng chính của Trojan là điều khiển máy tính từ xa, ăn cắp thông tin của nạn nhân hoặc làm nhiệm vụ backdoor.

Những Dạng Tấn Công Cơ Bản

Malicious Software

50

9/16/2025

➤ Backdoors

- Backdoors là những đoạn chương trình bí mật thường được đính kèm vào những chương trình khác nhằm giúp kẻ tấn công sau khi đã xâm nhập được vào hệ thống mở sẵn những lối vào (cổng hậu)..
- Khi được chạy trên máy nạn nhân, Backdoors sẽ thường trực trong bộ nhớ, mở một port (mặc định hoặc do kẻ tấn công quy định) giúp kẻ tấn công dễ dàng đột nhập vào máy nạn nhân thông qua port này

Những Dạng Tấn Công Cơ Bản

Malicious Software

51

9/16/2025

➤ Logic bombs

- Bom logic là chương trình con hoặc lệnh được nhúng trong một chương trình. Sự thi hành của nó được kích hoạt bởi câu lệnh điều kiện.
- Ví dụ, một nhân viên công ty làm việc trên một dự án phát triển có thể cài đặt một quả bom logic bên trong một chương trình. Quả bom được kích hoạt chỉ nếu nhân viên này đã không chạy chương trình trong một thời gian nhất định. Khi điều kiện được đáp ứng, có nghĩa là nhân viên này đã bị sa thải một thời gian trước đó. Quả bom logic trong trường hợp này được sử dụng để trả thù chống lại chủ nhân

Những Dạng Tấn Công Cơ Bản

Malicious Software

52

9/16/2025

➤ Spyware

- Spyware là một loại phần mềm tự cài đặt chính nó trên máy tính của người dùng. Spyware thường được sử dụng để theo dõi xem người dùng làm gì và quấy rối họ với những thông điệp thương mại xuất hiện trong những cửa sổ popup.
- Thường gồm các loại Browser hijacking và Zombieware.

Nội Dung

53

9/16/2025

- Bảo mật thông tin là gì
- Những thách thức trong bảo mật thông tin
- Những dạng tấn công cơ bản trên mạng
- **Phân loại người tấn công**
- Mô hình quản lý hệ thống IT của doanh nghiệp

Phân Loại Người Tấn Công

54

9/16/2025

- Black-hat hackers
- Script kiddies
- Cyber spies
- Vicious employees
- Cyber terrorists

Phân Loại Người Tấn Công

Black-hat hackers

55

9/16/2025

- Hackers là những người có tri thức đặc biệt về hệ thống máy tính. Họ quan tâm đến những chi tiết tinh tế của phần mềm, giải thuật, mạng máy tính và cấu hình hệ thống. Họ là một nhóm người ưu tú, năng động, được đào tạo tốt.
- Tùy theo mục đích, hackers được chia thành hackers mũ đen, hackers mũ trắng và hackers mũ xám

Phân Loại Người Tấn Công

Script kiddies

56

9/16/2025

- Là những người sử dụng các script hoặc các chương trình được phát triển bởi các hacker mũ đen (những công cụ hack) để tấn công các máy tính và gây thiệt hại cho người khác.
- Script kiddies chỉ biết sử dụng công cụ hack để tấn công các mục tiêu chứ không hiểu cách thức hoạt động và cũng không có khả năng viết ra những công cụ tương tự.
- Đa số Script kiddies chỉ là những thanh thiếu niên, không đủ nhận thức và chín chắn để hiểu hết những hậu quả do mình gây ra.

Phân Loại Người Tấn Công

Cyber spies

57

9/16/2025

- Có thể hoạt động trên lãnh vực quân sự, kinh tế,...
- Đánh chặn truyền thông trên mạng và phá mã các thông điệp đã được mã hoá.
- Nhiều tổ chức tình báo lớn trên thế giới đã thuê các nhà toán học, các nhà khoa học máy tính, các giáo sư đại học làm việc cho họ để phát triển các công cụ nhằm chống lại loại tội phạm này

Phân Loại Người Tấn Công

Vicious employees

58

9/16/2025

- Là những người cố tình vi phạm an ninh để làm hại những người sử dụng họ.
- Tấn công máy tính công ty để kiếm sự quan tâm từ những người lãnh đạo.
- Hoạt động như gián điệp mạng để thu thập và bán bí mật của công ty.

Phân Loại Người Tấn Công

Cyber terrorists

59

9/16/2025

- Black-hat hackers
- Script kiddies
- Cyber spies
- Vicious employees
- Cyber terrorists

Nội Dung

60

9/16/2025

- Bảo mật thông tin là gì
- Những thách thức trong bảo mật thông tin
- Những dạng tấn công cơ bản trên mạng
- Phân loại người tấn công
- **Mô hình quản lý hệ thống IT của doanh nghiệp**

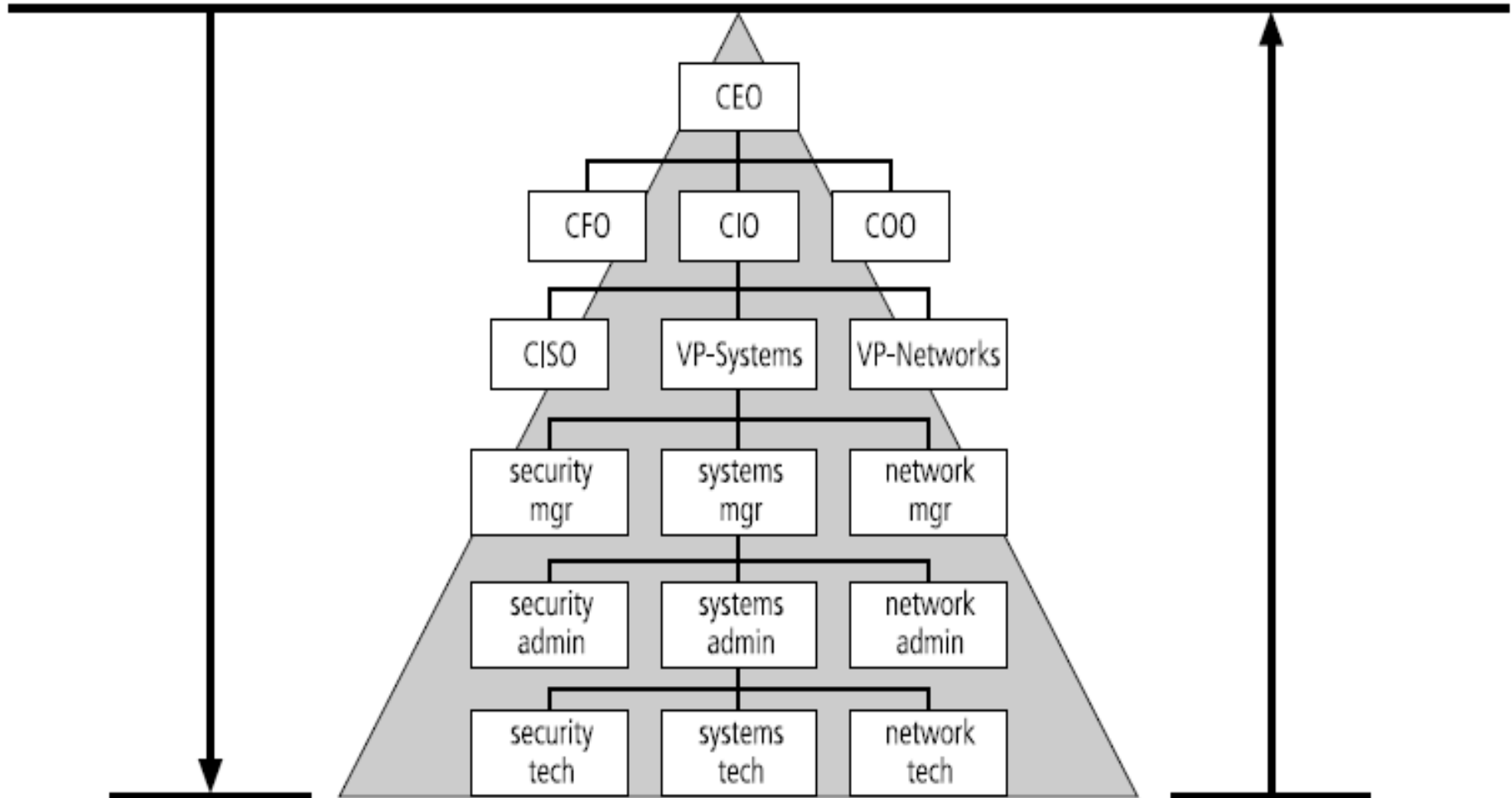
MÔ HÌNH QUẢN LÝ HỆ THỐNG IT TRONG DOANH NGHIỆP

61

9/16/2025

Top-down approach

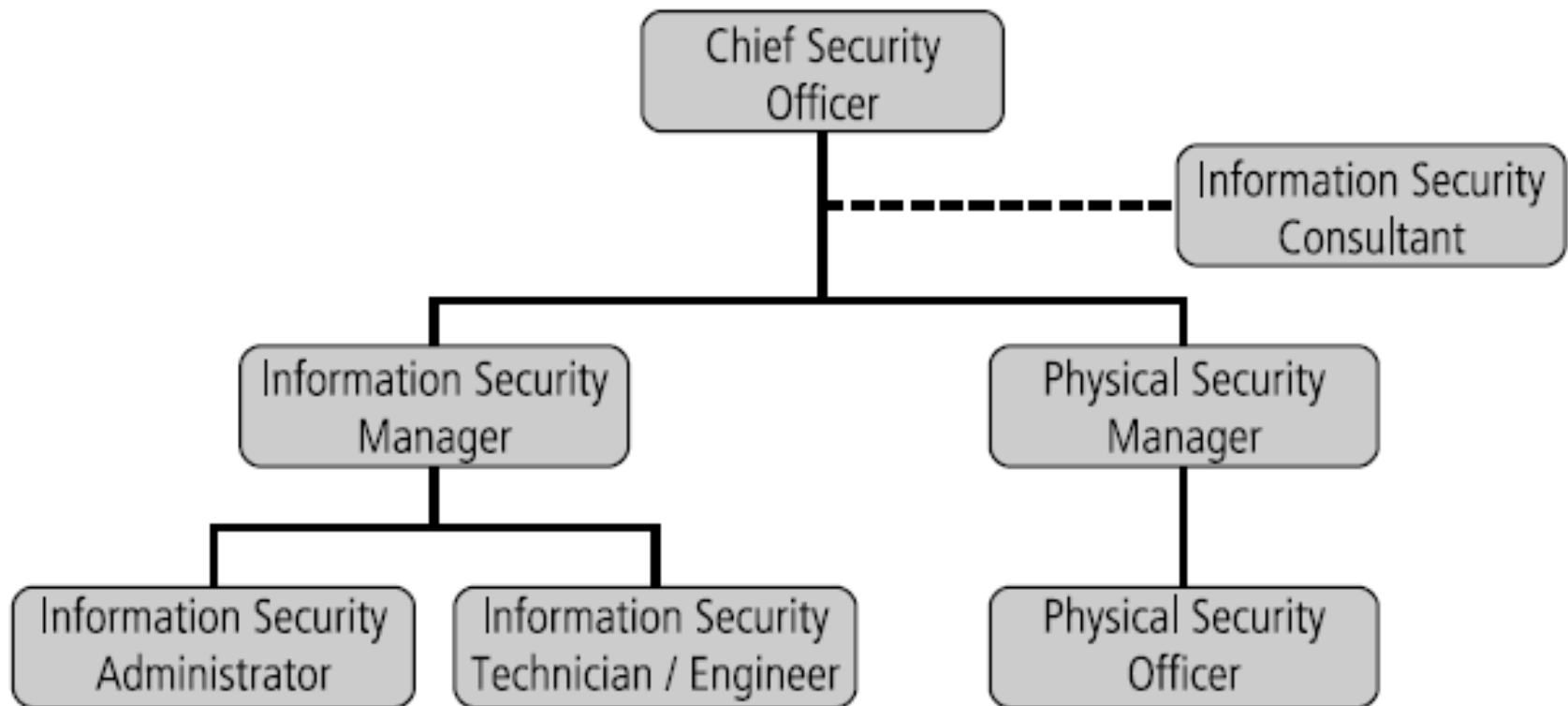
Bottom-up approach



MÔ HÌNH QUẢN LÝ HỆ THỐNG IT TRONG DOANH NGHIỆP

62

9/16/2025



Question ???